Slides S04: Cơ chế Thu hồi & Phân tích Trạng thái Chứng chỉ

Học phần: Cơ sở hạ tầng khóa công khai (ATHK 512) · Lớp CHAT4P
Giảng viên: Nguyễn An Khương (Khoa Khoa học & Kỹ thuật Máy tính, Trường ĐHBK Tp. HCM)
Trợ giảng: Nguyễn Hữu Hoàng Huy

Slide 1: Nghịch lý của Cơ chế Thu hồi

- Phát hành chứng thư số rất nhanh, nhưng **thu hồi chứng thư số kịp thời** là một trong những bài toán phức tạp nhất của an toàn thông tin!
- Nếu client không kiểm tra thu hồi: Chứng chỉ bị đánh cắp vẫn được coi là hợp lệ cho tới khi hết hạn.
- Nếu client kiểm tra nghiêm ngặt (Hard-fail): Bất kỳ sự cố mạng nào tới CA cũng làm sập toàn bộ dịch vụ.

Slide 2: So sánh Chi phí Băng thông & Độ trễ

Tiêu chí	CRL truyền thống	OCSP trực tiếp	OCSP Stapling
Băng thông Client	Rất lớn (tải tệp MB)	Nhỏ (~2 KB)	Tối ưu (nhúng sẵn)
Độ trễ bắt tay TLS	Chậm lần đầu	Thêm 1 RTT tới CA	0 RTT phát sinh
Bảo vệ quyền riêng tư	Trung bình	Kém (CA theo dõi IP)	Rất cao
Khả năng chịu tải	Phụ thuộc CDN	CA dễ bị nghẽn	Máy chủ web tự chịu tải

---

Slide 3: Cấu trúc Ghi nhận Certificate Transparency

- Không một chứng chỉ công cộng nào được tin cậy nếu thiếu **Signed Certificate Timestamp (SCT)** từ ít nhất 2 CT Logs độc lập.
- Cây Merkle bảo đảm tính chất **Chỉ ghi thêm (Append-only)**:
  - Không ai (kể cả quản trị viên CT Log) có thể xóa, sửa đổi hoặc chèn lén chứng chỉ trong quá khứ mà không làm sai lệch Root Hash của toàn bộ cây.